מחלקת תקשוב · רשתות · מדריך למעביר השיעור

# Domain, אימות, הצפנה ותעודות

הסבר לכל שקופית: מה מראים, מה צריך להבין כדי להסביר את זה, אילו שאלות יעלו ואיפה חניכים נוטים לטעות.

| 19 | כ-75 דקות | 5 דקות |
| --- | --- | --- |
| שקופיות | משך מומלץ | פער שעון שמעליו Kerberos דוחה בקשה |

לטכנאי שטח בסביבת Windows מנוהלת · ההרחבה בהצפנה ובתעודות נמצאת בשיעור 8

# מטרה, הכנה וחלוקת זמן

## למי המדריך ומה המטרה

המדריך כתוב למי שמעביר את השיעור ולא בהכרח ניהל Domain. הרקע בכל שקופית רחב ממה שעל המסך, כדי שתוכלו לענות כשחניך שואל "למה".

לעקוב עם הכיתה אחרי כניסת משתמש לתחנה ב-Domain ואחרי חיבור לשירות מאובטח ב-TLS, ולשאול בכל שלב מה חייב לעבוד כדי שהוא יצליח. בסוף השיעור חניך אמור להסביר איך תחנה מוצאת Domain Controller, להפריד בין אימות להרשאה, להסביר למה שעון שגוי מפיל כניסה, להבחין בין הצפנה סימטרית לאסימטרית, לקרוא תעודה ולשייך שגיאת TLS למשפחה שלה: זמן, שם, אמון או משא ומתן. שמות של אלגוריתמים והודעות לא צריך לזכור.

## הכנה

- פתחו את המצגת ב-Chrome או ב-Edge במחשב המקרן ועברו על כל השקופיות. המצגת לא צריכה רשת. שקופיות 2, 7, 8 ו-17 חיות: לוחצים על כפתורים, ובשקופית 8 גם גוררים מחוון, והתוצאה מתעדכנת מיד. נסו כל אחת מהן לפני השיעור לפי סעיפי "ההדגמה".
- הניווט: חצים או רווח, N הערות המדריך, F מסך מלא, A אנימציות. אין במצגת תיבות טקסט. אחרי לחיצה בעכבר על כפתור בהדגמה, החצים והרווח ממשיכים להעביר שקופיות. את מחוון הדקות בשקופית 8 מזיזים בעכבר; מי שנכנס אליו במקלדת (Tab) מזיז אותו בחצים, ו-Esc מחזיר את החצים לניווט.
- מספרי השקופיות במדריך הם המספרים שבמונה בתחתית המסך ("2 / 19"). המספר הקטן שליד הכותרת נמוך באחד, כי שקופית השער לא ממוספרת.
- ודאו שהקבוצה מכירה DNS, כתובת IP ו-Gateway מהשיעור הקודם, והכינו דוגמה להודעת שגיאה של תעודה או של כניסה ל-Domain, בלי פרטים רגישים.
- עברו מראש על רצף ה-Handshake בשקופית 15. בכיתה מסבירים את סדר השלבים ואת התקלות, בלי לפרק כל הודעה; את ההודעות אחת אחת מראים בשיעור 8. אם יש תחנה שמחוברת ל-Domain, אפשר להריץ עליה את הפקודות מסעיפי "בשטח" (רשימה בנספח).

> **מה לא מלמדים בשיעור הזה**
>
> ניהול Active Directory, כתיבת GPO והקמת CA לא נכללים. מי מתקן ערוץ מאובטח, מצרף תחנה מחדש או משנה מדיניות נקבע בנוהל היחידה.

## חלוקת זמן מוצעת (75 דקות)

| חלק | שקופיות | מה מעבירים | דקות |
|---|---|---|---|
| **פתיחה** | 1-2 | מצב התחנה: מה המשתמש מקבל כשתשתית אחת נשברת | 7 |
| **חשבונות, איתור DC והצטרפות** | 3-5 | Domain וחשבון המחשב, רשומות SRV, ערוץ מאובטח | 10 |
| **אימות והרשאה** | 6-9 | הרשאות, Kerberos צעד אחר צעד, שעון התחנה ו-Group Policy | 15 |
| **סוגי הצפנה** | 10-11 | יעדי האבטחה, תפקיד ההצפנה האסימטרית והסימטרית | 8 |

| | | | |
|---|---|---|---|
| **תעודות ומשא ומתן** | 12-14 | תעודה, שרשרת אמון ו-Cipher Suite | 10 |
| **TLS Handshake** | 15-16 | רצף ההודעות ומשפחות תקלה | 10 |
| **תרגול** | 17 | מהדיווח של המשתמש לחוליה שנשברה | 10 |
| **סגירה** | 18-19 | מגבלות ההדגמות ושרשרת התלות | 5 |

בלי ההדגמות השיעור לקח 55 דקות. ההדגמות בשקופיות 2, 7 ו-8 מוסיפות כ-8 דקות, התרגול 10 ושקופית המגבלות 2. כשהזמן קצר, בתרגול עוברים רק על דיווחים 1 ו-3 (חוסך כ-5 דקות), ובשקופית 8 מסתפקים בברירת המחדל וב״שנה אחורה״. את שקופית המגבלות לא מדלגים.

# פתיחה: תחנה ב-Domain

## שקופית 1 · בסביבת Windows, זהות ו-TLS נשענים על DNS, זמן ושרשרת אמון

הציגו את שני התהליכים שהשיעור עוקב אחריהם, כניסה לתחנה וחיבור לשירות מאובטח, ושאלו את שאלת הפתיחה: **איך שעון שגוי יכול לגרום לכניסה להיכשל גם כשהסיסמה נכונה והרשת זמינה?** אל תענו עכשיו. בשקופית 2 רואים שזה קורה, ובשקופית 8 למה. ניהול Domain נשאר מחוץ לשיעור.

## שקופית 2 · על מה נשענות כניסה וגישה לשירותים

**על המסך:** בצד ימין ״מצב התחנה״, עם מתגים לרשת, לשרת ה-DNS, לשעון, לחשבון המחשב, ל-Root של היחידה ולקבוצה של התיקייה. בצד שמאל טבלה של פעולות משתמש: כניסה ראשונה לתחנה, פתיחת \\fs01\docs וגלישה ל-portal.unit.local. לכל פעולה מופיעות התשתיות שהיא נשענת עליהן (ירוק תקין, אדום תקול) ומה המשתמש מקבל: הצלחה או כישלון, ההודעה שהוא רואה, ובשורה קטנה הסיבה.

**רקע.** לאורך כל השיעור המשתמש רואה הודעת כניסה, ״אין הרשאה״ או שגיאת תעודה, והסיבה יושבת בשכבה אחרת. כאן הכיתה רואה את זה עוד לפני המנגנונים, וכל עמודה מוסברת בשקופיות הבאות.

- **רשת ו-DNS.** כדי להיכנס, התחנה צריכה למצוא DC, והיא מוצאת אותו ברשומות SRV שנמצאות רק ב-DNS של ה-Domain (שקופית 4). בלי רשת, או עם DNS חיצוני, המשתמש מקבל ״אין שרת כניסה זמין״. עם DNS חיצוני גם השם של האתר הפנימי לא נמצא, אף שהגלישה לאינטרנט עשויה לעבוד.
- **שעון.** Kerberos דוחה בקשות כשהפער מול ה-DC גדול מ-5 דקות (שקופית 8), ולכן ״10+ דקות״ מפיל את הכניסה. תעודה תקפה לחודשים, ופער של דקות לא משנה לה. ״שנה אחורה״ מפיל את שתיהן: את הכניסה בגלל Kerberos ואת האתר כי לפי שעון התחנה התעודה עוד לא בתוקף.
- **חשבון המחשב.** אם הסוד של חשבון המחשב בתחנה לא תואם את ה-DC (שקופיות 3 ו-5), הכניסה נכשלת ב״יחסי האמון בין התחנה ל-Domain נכשלו״. האתר לא מושפע, כי TLS לא משתמש בחשבון המחשב.
- **Root.** משפיע רק על האתר: בלי ה-Root הפנימי במאגר האמון השרשרת לא נסגרת (שקופית 13). כניסה בסיסמה לא משתמשת בתעודות.
- **קבוצה.** משפיעה רק על התיקייה. הכניסה עוברת, כלומר האימות תקין, והגישה נחסמת בהרשאה (שקופית 6).

בשורת הכניסה הטבלה מציגה את התקלה הראשונה לפי הסדר שבו התחנה עובדת: מגיעה לרשת, מאתרת DC ב-DNS, מבקשת כרטיס (כאן נבדק השעון), ורק אחר כך נבדק הקשר של התחנה עצמה עם ה-DC. כשהכניסה נכשלת, פתיחת התיקייה ״לא נבדקה״, כי אין משתמש מחובר. בשורת האתר, כשגם התאריך וגם ה-Root לא תקינים, מופיעות שתי הסיבות.

הכניסה בטבלה היא **כניסה ראשונה** של המשתמש לתחנה. משתמש שכבר נכנס בה בעבר יכול להיכנס מנתונים שמורים כשה-DC לא זמין (שקופית 5), ואז התקלה מופיעה מאוחר יותר, בתיקיות ובמדיניות.

**ההדגמה.** ברירת המחדל: הכול תקין חוץ מהשעון, שמקדים ב-10 דקות. הכיתה רואה בשורה הראשונה ״✗ נכשלת״ ו״הודעה על הפרש שעה ותאריך בין התחנה לשרת״, עם ״שעון״ באדום. התיקייה ״לא נבדקה״, והאתר ״✓ מצליחה״ עם ״פער של דקות לא משנה לתעודה שתקפה לשנה״. אחר כך:

- לחצו ״שנה אחורה״: גם האתר נכשל, ״שגיאת תעודה ERR_CERT_DATE_INVALID״, ו״תאריך״ נצבע באדום.
- החזירו ל״מדויק״ ולחצו ״חיצוני״ ב-DNS: בכניסה ״אין שרת כניסה זמין״, ובאתר ״השם לא נמצא״.
- החזירו את ה-DNS ולחצו ״לא חבר״ בקבוצה: הכניסה מצליחה, התיקייה מחזירה ״אין הרשאת גישה״, והאתר עובד.

- אם נשאר זמן: "חסר" ב-Root נותן רק ERR_CERT_AUTHORITY_INVALID באתר, ו"סוד לא תואם" בחשבון המחשב נותן רק את הודעת יחסי האמון.

לא מסבירים עכשיו Kerberos או תעודות. הטבלה חוזרת בתרגול בשקופית 17, שם עובדים בכיוון ההפוך: מהדיווח של המשתמש למצב התחנה.

**בשטח.** כשמשתמש מדווח "לא מצליח להיכנס", מבקשים את נוסח ההודעה המדויק, כי הוא מצביע על השכבה. ב-Windows באנגלית ההודעות נראות כך:

| בטבלה | הנוסח ב-Windows | איפה מחפשים |
|---|---|---|
| **אין שרת כניסה זמין** | There are currently no logon servers available to service the logon request. | רשת ו-DNS |
| **הפרש שעה ותאריך** | There is a time and/or date difference between the client and server. | שעון התחנה |
| **יחסי האמון נכשלו** | The trust relationship between this workstation and the primary domain failed. | חשבון המחשב |
| **אין הרשאת גישה** | Access is denied. | קבוצות והרשאות |

| שאלה | תשובה |
|---|---|
| **עם DNS חיצוני האינטרנט עובד. איך זה שהכניסה נכשלת?** | DNS ציבורי יודע לענות על שמות באינטרנט, אבל אין בו את הרשומות של ה-Domain ושל השרתים הפנימיים. |
| **למה כשהשעון זז בעשר דקות האתר עובד?** | תעודה נבדקת מול תאריכי תוקף של חודשים. רק Kerberos רגיש לדקות. |

**טעות נפוצה**

"כל כשל בכניסה הוא בעיית סיסמה". בטבלה רואים כשלי כניסה בגלל רשת, DNS, שעון וחשבון המחשב, ובאף אחד מהם איפוס סיסמה לא עוזר.

# אובייקטים, DNS והצטרפות ל-Domain

## שקופית 3 · ב-Domain יש חשבון גם למשתמש וגם למחשב

**על המסך:** Domain Controller במרכז (זהות, DNS, מדיניות), ומסביבו משתמש (חשבון Domain), תחנה (חשבון מחשב), קבוצה (הרשאות) ושרת (שירות מוגן). כולם נשענים על אותו DC. בכותרת המשנה: ה-DC מחזיק את Active Directory, ומחשב שייך ל-Domain לפי הניהול ויחסי האמון, בלי קשר למיקום הפיזי או ל-VLAN.

**רקע.** בלי Domain, כל מחשב Windows מחזיק רשימת משתמשים משלו, ומי שעובד על עשר תחנות צריך עשרה חשבונות. ב-Domain יש מאגר זהויות אחד, Active Directory, והמחשבים סומכים עליו: משתמש נכנס לכל תחנה בחשבון אחד, וההרשאות והמדיניות מוגדרות במקום אחד.

Domain Controller הוא שרת שמחזיק עותק של המאגר ומספק את השירותים: אימות (Kerberos), שאילתות על המאגר (LDAP), ובדרך כלל גם DNS. ברוב הרשתות יש יותר מ-DC אחד, והם משכפלים ביניהם שינויים, כך שנפילה של אחד לא עוצרת כניסות.

**Domain ו-DNS Domain:** ל-Domain של AD יש שם DNS (למשל unit.local), אבל שם DNS לבדו, כמו כתובת של אתר, הוא רק מרחב שמות, בלי משתמשים, סיסמאות או מדיניות. **Domain ו-Subnet:** Subnet ו-VLAN שייכים לחלוקת הרשת, ואין להם קשר לשייכות ל-Domain. שתי תחנות באותו Subnet יכולות להיות ב-Domain שונה, ותחנה שעוברת ל-VLAN אחר נשארת חברה ב-Domain שלה. השייכות נקבעת בניהול וביחסי האמון.

**אובייקטים.** כל מה שה-Domain מכיר הוא אובייקט במאגר, ולכל אובייקט יש מזהה ייחודי (SID). ההרשאות על קבצים נשמרות לפי ה-SID, ולכן משתמש שנמחק ונוצר מחדש באותו שם מקבל SID חדש, וההרשאות הישנות לא חוזרות אליו. קבוצות מחברות בין זהות לגישה: נותנים הרשאה לקבוצה ומוסיפים אליה משתמשים. מדיניות (GPO) היא אובייקט שמקושר לחלק מעץ ה-AD (שקופית 9).

מה שהחניך צריך להכיר הוא **אובייקט המחשב**. תחנה שהצטרפה ל-Domain מחזיקה חשבון משלה (בשם התחנה, עם $ בסוף) וסיסמה שהיא וה-DC מכירים. את הסיסמה הזו התחנה מחליפה בעצמה, בברירת מחדל פעם ב-30 יום. אם החשבון נמחק, או שהסוד שבתחנה כבר לא תואם את ה-DC, התחנה נתקלת בבעיות מול ה-Domain. מקרה אופייני: תחנה ששוחזרה מגיבוי או מתמונה ישנה חוזרת עם סיסמה שכבר הוחלפה. ההודעה בכניסה היא בדרך כלל The trust relationship between this workstation and the primary domain failed.

תכנון OU וניהול הרשאות לא נכנסים כאן.

**בשטח.** whoami מראה בשם מי מחוברים: UNIT\user הוא חשבון Domain, ושם התחנה לפני הלוכסן מסמן חשבון מקומי. echo %LOGONSERVER% מראה איזה DC אימת את הכניסה.

| שאלה | תשובה |
|---|---|
| **אם מעבירים תחנה ל-VLAN אחר, היא יוצאת מה-Domain?** | היא נשארת חברה. אבל אם מה-VLAN החדש אין דרך ל-DC או ל-DNS שלו, היא לא תוכל להשתמש בשירותים שלו. |

## שקופית 4 · תחנה מאתרת Domain Controller באמצעות DNS

**על המסך:** התחנה שואלת את ה-DNS מי מספק Kerberos, מקבלת DC01.domain מרשומות SRV ופונה ל-DC.

**רקע.** רשומת A מתרגמת שם לכתובת. רשומת SRV עונה על שאלה אחרת: איזה שרת נותן שירות מסוים ובאיזה פורט. כל DC רושם ב-DNS רשומות כאלה על עצמו, למשל _ldap._tcp.dc._msdcs.unit.local. תחנה שצריכה DC שואלת עליהן, מקבלת רשימת DC-ים ופונה לאחד מהם, בדרך כלל לקרוב אליה.

הרשומות נמצאות רק ב-DNS של ה-Domain. לכן תחנה עם DNS ציבורי יכולה לגלוש באינטרנט ועדיין להפיל את ה-Domain, כי דרכו היא לא מאתרת את ה-DC. מבלבל יותר: DNS ראשי פנימי ומשני חיצוני. כשהראשי לא עונה בזמן, התחנה פונה למשני, מקבלת "אין רשומה כזו", והתקלה מופיעה ונעלמת. כשיש IP אבל הכניסה ל-Domain נכשלת, DNS שגוי הוא מהחשודים הראשונים.

**בשטח.** ipconfig /all מראה אילו שרתי DNS התחנה מקבלת. nltest /dsgetdc:unit.local (עם שם ה-Domain האמיתי) מריץ את תהליך האיתור ומחזיר את ה-DC שנמצא.

> **טעות נפוצה**
>
> "יש ping ל-DC, אז DNS תקין". Ping לכתובת IP בודק רק את הנתיב ברשת, ולא את השאלה אם ה-DNS של התחנה מכיר את רשומות ה-SRV.

## שקופית 5 · Domain Join יוצר למחשב חשבון וערוץ מאובטח

**על המסך:** תחנה חדשה עם זהות מקומית שולחת בקשת הצטרפות, ה-DC יוצר חשבון מחשב וסוד משותף, והתוצאה היא תחנת Domain עם ערוץ מאובטח.

**רקע.** בהצטרפות התחנה מאתרת DC דרך DNS, מי שמבצע את ההצטרפות מזדהה בחשבון שמותר לו לצרף מחשבים, ונוצר אובייקט מחשב. התחנה וה-DC קובעים לו סיסמה, וזה הסוד המשותף שבתרשים. אחרי אתחול התחנה פותחת בעזרתו ערוץ מאובטח (Secure Channel) מול DC, ומעכשיו היא עצמה יכולה להזדהות: היא מקבלת מדיניות מחשב עוד לפני שמשתמש נכנס, ומאמתת מול ה-DC משתמשים שמקלידים סיסמה.

הרצף כולו: DNS מתאים ← איתור DC ← חשבון מחשב ← ערוץ מאובטח ← קבלת מדיניות. כשמשהו נשבר, הולכים עליו מההתחלה.

**כניסה מה-Cache.** Windows שומר נתוני אימות של הכניסות האחרונות (בברירת מחדל עשר), כדי שמשתמש במחשב נייד יוכל להיכנס גם בלי חיבור ל-DC. לכן אם הערוץ המאובטח נשבר, המשתמש עשוי להיכנס עם Cache, אבל פעולות Domain אחרות ייכשלו: כוננים ממופים, מדיניות, גישה לשרתים.

**בשטח.** Test-ComputerSecureChannel ב-PowerShell בודק את הערוץ ומחזיר True או False. תיקון או הצטרפות מחדש דורשים הרשאות ב-Domain, ומי מבצע אותם נקבע בנוהל היחידה.

# אימות, Kerberos, זמן ומדיניות

## שקופית 6 · אימות בודק מי המשתמש, והרשאה קובעת מה מותר לו

**על המסך:** אימות שואל ״מי אתה?״ ומוציא זהות מאומתת. הרשאה שואלת ״מה מותר לך?״ לפי קבוצות, ACL ומדיניות.

**רקע.** אימות מסתיים כשהמערכת יודעת מי המשתמש. הרשאה נבדקת בכל גישה למשאב. בכניסה Windows בונה למשתמש ״אסימון גישה״ עם ה-SID שלו ושל כל הקבוצות שלו, ובכל פתיחה של תיקייה משווה אותו לרשימת ההרשאות (ACL) שלה. בתיקייה משותפת יש שתי רשימות, הרשאות השיתוף והרשאות NTFS, והגישה בפועל היא המחמירה מביניהן.

מכאן תקלה נפוצה: מוסיפים משתמש לקבוצה, והוא עדיין לא נכנס לתיקייה. האסימון נבנה בכניסה, ולכן הקבוצה החדשה נכנסת לתוקף בדרך כלל רק אחרי יציאה וכניסה מחדש. whoami /groups מציג את הקבוצות שבאסימון הנוכחי.

**שאלת ביניים**

משתמש נכנס לתחנה אך אינו פותח תיקייה. האם זו בהכרח בעיית סיסמה? הכניסה הצליחה, כלומר האימות עבר. התקלה בהרשאה, ואינה בהכרח קשורה לסיסמה או לקשר ל-DC.

**טעות נפוצה**

לאפס סיסמה כדי לפתור בעיית גישה לתיקייה. איפוס סיסמה לא נוגע בהרשאות, והמשתמש נכנס עם סיסמה חדשה ועדיין לא פותח את התיקייה.

## שקופית 7 · Kerberos משתמש בכרטיסים כדי להוכיח זהות לשירותים

**על המסך:** הדגמה צעד אחר צעד. משמאל תרשים עם התחנה, ה-DC (KDC) ושרת הקבצים fs01, ובו נוספת הודעה בכל צעד. מימין הסבר הצעד וחלון klist מקוצר שמראה אילו כרטיסים יש לתחנה.

**רקע.** Kerberos היא שיטת האימות של Domain ב-Windows מאז Windows 2000. הרעיון דומה לאישור כניסה לבסיס: מזדהים פעם אחת, מקבלים אישור מוגבל בזמן, ומציגים אותו בכל שער. השירות שמנפיק את הכרטיסים, KDC, רץ על כל DC. יש שני שלבים, ובהדגמה רואים את שניהם:

- בכניסה התחנה מוכיחה שהמשתמש יודע את הסיסמה בלי לשלוח אותה: היא מצפינה את השעה הנוכחית במפתח שנגזר מהסיסמה, וה-KDC בודק שהוא מצליח לפענח. בתמורה היא מקבלת כרטיס ראשי (TGT), בברירת מחדל לעשר שעות.
- כשניגשים לשירות, למשל לשרת קבצים, התחנה מציגה את הכרטיס הראשי ומקבלת כרטיס לשירות המסוים. אותו היא מציגה לשרת, והשרת בודק אותו בעצמו בלי לפנות ל-DC.

הסיסמה לא נשלחת לשרת וגם לא ל-DC. בכרטיס יש גם את קבוצות המשתמש, שעליהן מבוססת ההרשאה. כרטיס שירות מונפק לשם של השירות, ולכן Kerberos צריך שמות תקינים. בגישה לפי כתובת IP, למשל \\10.0.0.5\share, Windows בדרך כלל עובר לשיטה הישנה, NTLM, ואם היא חסומה, הגישה נכשלת. אין צורך ללמד את שמות כל הכרטיסים. הדגישו ש-DNS וזמן נדרשים לפני שהכרטיס יכול לעבוד.

מי יכול לפתוח כל כרטיס: ה-TGT מוצפן במפתח של ה-KDC עצמו (חשבון krbtgt), ולכן התחנה לא יכולה לקרוא או לשנות אותו, רק להציג אותו. כרטיס השירות מוצפן במפתח של חשבון השירות, ובשרת קבצים זה חשבון המחשב fs01$. כאן חשבון המחשב משקופית 3 מקבל תפקיד: בזכותו השרת פותח את הכרטיס ומאמין לו בלי לשאול את ה-DC.

כניסה בכרטיס חכם עוברת גם היא ב-Kerberos, בגרסה מבוססת תעודות שנקראת PKINIT (שיעור 8, שקופית 13).

**ההדגמה.** לחצו ״צעד הבא״. המונה מתחיל ב-1 / 7, ״צעד קודם״ חוזר אחורה ו-⟲ מתחיל מחדש. ההודעה הנוכחית מודגשת ונקודה לבנה נעה עליה; הודעות קודמות מעומעמות.

| מונה | מה קורה | חלון klist |
|---|---|---|
| 1 | המשתמש מקליד סיסמה, והתחנה גוזרת ממנה מפתח (״סיסמה ← מפתח״). | Cached Tickets: (0) |
| 2 | בקשת TGT: שם המשתמש והשעה, מוצפנת במפתח מהסיסמה. ה-KDC בודק את השעה. | ללא שינוי |
| 3 | ה-KDC מחזיר TGT ומפתח Session. | נוסף krbtgt/UNIT.LOCAL, 08:00:00 עד 18:00:00 |
| 4 | בשעה 08:05 המשתמש פותח את \\fs01\docs; התחנה שולחת את ה-TGT ואת שם השירות cifs/fs01.unit.local. | ללא שינוי |
| 5 | ה-KDC מחזיר כרטיס שירות ל-fs01. | נוסף cifs/fs01.unit.local, 08:05:00 עד 18:00:00 |
| 6 | התחנה מציגה את הכרטיס לשרת עם הוכחה שכוללת את השעה. השרת פותח אותו במפתח של fs01$, בודק שעה וקבוצות. | ללא שינוי |
| 7 | גישה חוזרת לאותו שרת: אותו כרטיס, בלי DC. | ללא שינוי |

הפרט ששווה לעצור עליו בחלון klist: כרטיס השירות הונפק ב-08:05 ונגמר ב-18:00, כמו ה-TGT. כרטיס שירות לא תקף יותר מה-TGT שממנו הונפק. השמות AS, TGS ו-AP מופיעים בכותרות הצעדים בסוגריים, ואין צורך לזכור אותם. בגישה לשרת אחר חוזרים לצעדים 4 ו-5 (במונה) עם אותו TGT, ובחלון klist היה נוסף כרטיס לשרת ההוא.

**בשטח.** klist מציג את הכרטיסים שיש למשתמש, למי הונפקו ועד מתי הם תקפים. בתחנה אמיתית הרשימה ארוכה מבהדגמה: אחרי כניסה יש בדרך כלל גם כרטיסים לשירותים של ה-DC, שהתחנה צריכה בשביל המדיניות. klist purge מוחק אותם, והתחנה מבקשת חדשים בגישה הבאה.

> **טעות נפוצה**
>
> ״השרת שולח את הסיסמה ל-DC לבדיקה״. ב-Kerberos השרת לא רואה את הסיסמה ולא פונה ל-DC: הוא פותח את הכרטיס במפתח של עצמו.

## שקופית 8 · שעון שגוי נראה כמו תקלה באימות

**על המסך:** שעון ה-DC, שעון התחנה וההפרש ביניהם. מתחת מחוון דקות וכפתורי תאריך, ציר עם ״טווח מותר מול ה-DC״ ונקודה שמסמנת את התחנה, וטבלה: מי בודק את השעה ומה התוצאה, עבור בקשת כרטיס מה-DC, הצגת כרטיס לשרת הקבצים ותעודת portal.unit.local.

**רקע.** ב-Kerberos ההוכחה שהתחנה שולחת בכניסה היא השעה המוצפנת, וכל כרטיס תקף בין שתי שעות. כדי שהקלטה ישנה לא תתקבל, ה-DC דוחה בקשות כשהפער בין השעונים גדול מחמש דקות (ברירת המחדל). הסיסמה נכונה והרשת זמינה, והכניסה נכשלת. Windows מציג לפעמים הודעה על הפרש שעה ותאריך בין הלקוח לשרת, ולפעמים רק שגיאת אימות כללית.

ההשוואה נעשית בזמן אוניברסלי (UTC). אזור זמן שגוי לבדו לא מפיל את Kerberos. הבעיה מתחילה כשמשתמש ״מתקן״ ידנית את השעה המוצגת בתחנה עם אזור זמן שגוי, והשעון האמיתי זז בשעות.

ב-Domain השעה מגיעה בהיררכיה: התחנות מסתנכרנות מול ה-DC, וה-DC-ים מסתנכרנים בסופו של דבר מול DC אחד, שמחזיק תפקיד שנקרא PDC Emulator ומקבל שעה ממקור שנקבע לרשת. מהו המקור ביחידה נקבע בנוהל היחידה.

הבדיקה לא נעשית רק ב-DC. כל צד שמקבל הודעת Kerberos משווה את השעה שבהוכחה לשעון שלו: ה-DC בבקשות לכרטיסים, ושרת הקבצים כשמציגים לו כרטיס. לכן גם שרת שהשעון שלו זז יכול לדחות משתמשים תקינים. בהדגמה השרת מסונכרן ל-DC, ולכן שתי השורות הראשונות נכשלות יחד.

זמן מערכת שגוי מפיל גם תעודה, כ"טרם בתוקף" או כ"פגה", כי הדפדפן משווה את תאריכי התעודה לשעון המקומי (שקופית 16). Kerberos רגיש לדקות, ותעודה נופלת רק כשהתאריך יוצא מתקופת התוקף.

**ההדגמה.** שעון ה-DC קבוע: 10/11/2026 09:00:00. תעודת האתר בתוקף מ-15/07/2026 עד 15/07/2027. בברירת המחדל התחנה מקדימה ב-7 דקות: היא מראה 09:07:00 באדום, הנקודה על הציר מחוץ לפס הירוק, שתי שורות Kerberos "✗ נדחית" ו"✗ נדחה", והתעודה "✓ בתוקף".

- גררו ל-5+: "✓ מתקבלת". הגבול כולל 5 דקות.
- גררו ל-6−: שוב נדחה. הפער נספר לשני הכיוונים, ותחנה שמאחרת נכשלת כמו תחנה שמקדימה.
- לחצו "שנה אחורה": התאריך בתחנה 10/11/2025, Kerberos נדחה ("הפער שנה שלמה"), והתעודה "✗ התעודה עוד לא בתוקף"" עם ERR_CERT_DATE_INVALID.
- לחצו "שנה קדימה": 10/11/2027, והתעודה "פג תוקף". בשני המקרים הנקודה נדחקת לקצה הציר עם החץ.

**בשטח.** w32tm /query /status מראה מתי התחנה הסתנכרנה לאחרונה, ו-w32tm /query /source ממי היא מקבלת שעה. "Local CMOS Clock" כמקור אומר שהיא לא מסתנכרנת בכלל. סוללת שעון מרוקנת בלוח האם מחזירה את התאריך אחורה אחרי ניתוק מהחשמל.

> **טעות נפוצה**
>
> לשנות ידנית את השעה ב-DC כדי "ליישר" תחנה אחת. שינוי כזה מזיז את כל ה-Domain ביחס למקור הזמן. התיקון הוא בתחנה שסוטה, בסנכרון מול ה-Domain.

## שקופית 9 · מדיניות Domain יכולה לשנות שירותים, חומת אש ואמון בתחנה

**על המסך:** ה-DC מפיץ Group Policy עם הגדרות שירות, חומת אש ותעודות ואמון, והתחנה מקבלת אותה בעדכון ובריענון.

**רקע.** GPO יכול להפעיל או לבטל שירותים, לפתוח או לחסום פורטים בחומת האש, למפות כוננים, להתקין תעודות שורש פנימיות (שקופית 13) ולנעול הגדרות. מדיניות המחשב נטענת בעליית התחנה, מדיניות המשתמש בכניסה, ושתיהן מתרעננות ברקע, בברירת מחדל כל 90 דקות בערך. לכן, כמו בכותרת המשנה, הגדרה שרואים בתחנה לא בהכרח שונתה בה ידנית. הגדרה כזו מופיעה לרוב באפור, עם הודעה שחלק מההגדרות מנוהלות על ידי הארגון, ומי שמשנה אותה ידנית יגלה שהיא חוזרת בריענון הבא.

**בשטח.** מהטכנאי מצופה לאסוף gpresult ולבדוק אם המדיניות התקבלה בתחנה. gpresult /r מציג אילו GPO הוחלו (את חלק המחשב רואים רק בחלון עם הרשאות מנהל), ו-gpresult /h report.html מפיק דוח מלא שאפשר להעביר הלאה. gpupdate /force מושך את המדיניות מיד. כשמדיניות לא מגיעה, בדרך כלל התחנה לא מגיעה ל-DC (חוזרים לשקופיות 4-5). ניהול ה-GPO עצמו אינו בתחום של הטכנאי.

# יעדי האבטחה וסוגי הצפנה

## שקופית 10 · חיבור מאובטח צריך סודיות, שלמות ואימות זהות

**על המסך:** סודיות (מי שאין לו מפתח אינו קורא), שלמות (שינוי בתעבורה מתגלה), אימות (הלקוח בודק את זהות השרת). TLS מספק את שלושתם.

**רקע.** הציגו את היעדים לפני האלגוריתמים, כי כל רכיב ב-TLS קיים בשביל אחד מהם. שלמות פחות מובנת לחניכים: בלי בדיקת שלמות, תוקף שלא יודע לקרוא את התעבורה עדיין יכול לשנות בה ביטים, והצד השני יקבל מידע משובש בלי לדעת. לכן TLS מצרף לכל רשומה תג שמגלה שינוי.

הדגישו את האימות, כי בשבילו TLS צריך תעודה. אם מישהו ברשת מתחזה לשרת והלקוח רק מצפין, הלקוח יקים חיבור מוצפן מצוין עם המתחזה. הצפנה לבדה אינה מוכיחה שהצד השני הוא השרת הנכון. את זה מוכיחות התעודה וחתימת השרת (שקופיות 12-15). Kerberos עונה על אותה דרישה ב-Domain, בכרטיסים במקום תעודות.

מה הסמל בשורת הכתובת של הדפדפן מבטיח ומה לא מוסבר בשיעור 8, שקופית 9.

## שקופית 11 · הצפנה אסימטרית ב-Handshake, סימטרית לתעבורה

**על המסך:** אסימטרית: מפתח ציבורי ומפתח פרטי שנשאר אצל הבעלים, לזהות ולהסכמה על סוד משותף. סימטרית: אותו מפתח זמני בשני הצדדים, מהיר לתעבורה.

**רקע.** בהצפנה **סימטרית** אותו מפתח מצפין ומפענח. היא מהירה, ולכן מצפינים בה את המידע עצמו, בדרך כלל ב-AES. הבעיה שלה היא איך שני הצדדים מגיעים לאותו מפתח. בהצפנה **אסימטרית** לכל צד יש זוג מפתחות: הציבורי מתפרסם, והפרטי נשאר אצל בעליו. מה שנחתם במפתח הפרטי, כל אחד בודק במפתח הציבורי. היא איטית בסדרי גודל, ולכן משמשת רק בתחילת החיבור.

ב-Handshake של TLS 1.3 שני הצדדים מחליפים חצאים ציבוריים בשיטת דיפי-הלמן (ECDHE), וכל אחד מחשב מהם את אותו סוד. מי שמאזין רואה את שני החצאים ולא יכול לחשב את הסוד. בנוסף השרת חותם במפתח הפרטי של התעודה שלו, וכך מוכיח שהוא בעליה. מהסוד המשותף כל צד גוזר אצלו את מפתחות ה-Session, זמניים לחיבור אחד, ומשם התעבורה סימטרית.

אל תגידו שמפתח ה-Session פשוט נשלח ברשת. שני הצדדים גוזרים סוד משותף בלי לחשוף אותו. אם חניך מכיר את השיטה הישנה של TLS 1.2, שבה הלקוח הצפין סוד במפתח הציבורי של השרת ושלח אותו, ספרו לו שב-TLS 1.3 היא בוטלה: מי שהקליט תעבורה והשיג אחר כך את המפתח הפרטי של השרת יכול היה לפענח את ההקלטות. להרחבה: שיעור 8, שקופיות 6-8 ו-25.

# תעודה, שרשרת אמון ו-Cipher Suite

## שקופית 12 · תעודה קושרת שם למפתח ציבורי, והמנפיק חותם עליה

**על המסך:** תעודה לדוגמה: השם server.unit, מפתח ציבורי, המנפיק Unit-CA, תוקף 2026-2027 וחתימת המנפיק.

**רקע.** מפתח ציבורי לבדו הוא רצף מספרים בלי בעלים. התעודה קובעת "המפתח הזה שייך ל-server.unit", ורשות תעודות (CA) חותמת על הקביעה. הלקוח סומך על החתימה של ה-CA, ודרכה על השם שבתעודה.

בחלון התעודה של Windows רואים את השמות שהתעודה תקפה להם (Subject, ובעיקר Subject Alternative Name, הרשימה היחידה שדפדפנים מודרניים בודקים), את המפתח הציבורי, את המנפיק ואת תאריכי התוקף. תעודות של אתרים ציבוריים מונפקות היום לתקופה קצרה משנה (מאז מרץ 2026 עד 200 יום, והתקופה ממשיכה להתקצר), ותעודות של CA פנימי לפי מדיניות הארגון. המפתח הפרטי נשאר בשרת ואינו חלק מהתעודה.

הלקוח בודק שם, תוקף, מנפיק וחתימה לפני שהוא סומך על השירות. הפרידו בין התעודה, שהיא ציבורית, לבין המפתח הפרטי שנשאר אצל בעל הזהות, ולבין שרשרת האמון. אל תיכנסו למתמטיקה.

**בשטח.** בדפדפן פותחים את התעודה מהסמל שבתחילת שורת הכתובת: מנעול ב-Edge, וב-Chrome, מאז 2023, סמל הגדרות במקום המנעול. ב-Windows מאגר התעודות של המחשב נפתח ב-certlm.msc.

| שאלה | תשובה |
|---|---|
| **אם התעודה ציבורית, מה מונע ממני להעתיק אותה לשרת שלי?** | כלום, אבל בלי המפתח הפרטי השרת לא יוכל להוכיח שהיא שלו, וה-Handshake ייכשל (שקופית 15). |

> **טעות נפוצה**
>
> חניך מסביר שהתעודה "מצפינה את התעבורה". התעודה קושרת שם למפתח ציבורי. את התעבורה מצפין מפתח Session סימטרי שנגזר ב-Handshake.

## שקופית 13 · אמון נבנה מהתעודה דרך מנפיקים עד Root מוכר

**על המסך:** Root CA (עוגן אמון מקומי), Intermediate CA חתום על ידי ה-Root, ותעודת שרת חתומה על ידי ה-CA. הלקוח בונה שרשרת עד לעוגן שהוא כבר סומך עליו.

**רקע.** הלקוח בודק מי חתם על תעודת השרת, ואז מי חתם על החותם, עד תעודת Root. ה-Root חתום בידי עצמו, וסומכים עליו רק כי הוא מותקן מראש במאגר האמון (Trusted Root Certification Authorities). שורשים ציבוריים מגיעים עם Windows ועם העדכונים שלו. שורש פנימי מגיע לתחנות ה-Domain בדרך כלל דרך מדיניות (שקופית 9), ולכן תחנה שהמדיניות לא הגיעה אליה לא תסמוך על אתרים פנימיים.

שכבת ה-Intermediate קיימת כדי שהמפתח של ה-Root יישמר מנותק ומוגן. Intermediate יכול להגיע עם השירות, כשהשרת שולח אותו יחד עם התעודה שלו, או להיות מותקן בנפרד. כשהשרת לא שולח אותו, חלק מהלקוחות מורידים אותו לבד מכתובת שרשומה בתעודה, וחלק לא, וברשת סגורה ההורדה נכשלת. זו תקלה ש"עובדת אצלי" ולא אצל אחר. חוליה חסרה או Root שאינו מהימן שוברים את השרשרת.

**בשטח.** הלשונית Certification Path בחלון התעודה מציגה את השרשרת ומסמנת חוליה בעייתית.
certutil -verify -urlfetch server.cer בודק את כל השרשרת ואת זמינות כתובות הביטול. בשיעור 8, שקופית 11, יש בודק שרשרת עם תרחישי תקלה.

## שקופית 14 · הלקוח מציע אפשרויות, והשרת בוחר שילוב ששניהם תומכים בו

**על המסך:** ה-ClientHello מציע שלושה Cipher Suites, והשרת בוחר TLS_AES_128_GCM_SHA256, שמתפרק ל-AES_128_GCM (הצפנה סימטרית ושלמות) ול-SHA256 (Hash וגזירת מפתחות).

**רקע.** כל חיבור מתחיל במשא ומתן: הלקוח שולח רשימה של מה שהוא יודע, והשרת בוחר אפשרות אחת שגם הוא תומך בה. ב-TLS 1.3 שם ה-Cipher Suite מתאר רק את הצפנת התעבורה, שמוסיפה לכל רשומה גם תג שלמות, ואת ה-Hash. CHACHA20_POLY1305 מיועד בעיקר למכשירים בלי האצת AES בחומרה. חוץ מה-Cipher Suite מסכמים בנפרד על גרסה, על Key Exchange ועל אלגוריתם החתימה. ב-TLS 1.2 הכול היה בשם אחד ארוך, למשל TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256, וכאלה עדיין מופיעים בהגדרות של ציוד ישן.

את שמות האלגוריתמים לא צריך לזכור. החניך צריך להבין שאם אין התאמה, החיבור נופל עוד לפני שעובר מידע: השרת שולח הודעת שגיאה וסוגר, ו-Chrome ו-Edge מציגים ERR_SSL_VERSION_OR_CIPHER_MISMATCH.

**בשטח.** המקרה הנפוץ הוא ממשק ניהול של ציוד ישן (מדפסת, UPS, מתג) שתומך רק ב-TLS 1.0 או 1.1, שהדפדפנים כבר לא מסכימים להשתמש בהם. המקרה ההפוך הוא שרת שהוקשח ומסרב ללקוח ישן. ב-Windows כשלים של רכיבים שמשתמשים ב-TLS של מערכת ההפעלה (למשל שרת IIS, RDP או LDAPS) נרשמים ביומן System, במקור Schannel. Chrome ו-Edge משתמשים ברכיב TLS משלהם, והכשלים שלהם לא נרשמים שם.

# TLS Handshake ותקלות

## שקופית 15 · ה-Handshake מאמת את השרת וגוזר מפתחות לפני שעובר מידע יישומי

**על המסך:** תרשים הודעות בין לקוח לשרת. ClientHello ו-ServerHello עם key share, ומיד אחריהם ״שני הצדדים גוזרים מפתחות Handshake״. מתחת מסגרת מקווקוות, ״מוצפן במפתחות ה-Handshake״, ובה ההודעות של השרת (EncryptedExtensions, Certificate, CertificateVerify, Finished), בדיקת התעודה בלקוח וה-Finished של הלקוח. בסוף מפתחות התעבורה ו-Application Data. בתחתית: ״SSL״ הוא השם הישן, הפרוטוקול הוא TLS.

**רקע.** עברו על הרצף לפי הסדר:

| שלב | כיוון | מה עובר ולמה |
|---|---|---|
| 1 | מהלקוח | ClientHello: גרסאות, Cipher Suites, החצי הציבורי של דיפי-הלמן (key share) ושם השרת המבוקש. |
| 2 | מהשרת | ServerHello: מה שנבחר והחצי של השרת. מעכשיו שני הצדדים מחשבים את הסוד המשותף וגוזרים ממנו מפתחות Handshake. |
| 3 | מהשרת, מוצפן | EncryptedExtensions: שאר הגדרות החיבור. Certificate: התעודה והשרשרת. CertificateVerify: חתימה במפתח הפרטי על ההודעות עד כה, שמוכיחה שהשרת מחזיק את המפתח של התעודה. Finished של השרת. |
| 4 | בלקוח | אימות שם, תוקף, שרשרת וחתימה. כאן נולדות שגיאות התעודה. |
| 5 | מהלקוח, מוצפן | Finished של הלקוח. כל צד מוכיח ב-Finished שראה את אותן הודעות והגיע לאותם מפתחות. תוקף ששינה הודעה בדרך נתפס כאן. |
| 6 | דו-כיווני | Application Data מוצפנת סימטרית במפתחות התעבורה, שנגזרים מאותו סוד. |

הנקודה שחניכים מפספסים: ב-TLS 1.3 הצדדים גוזרים מפתחות כבר אחרי ה-ServerHello, וכל מה שהשרת שולח מהתעודה והלאה עובר מוצפן. ב-TLS 1.2 התעודה עברה גלויה, ומי שהאזין ראה אותה. לכיתה מספיק לזכור שהשרת מוכיח את זהותו כבר בתוך הערוץ המוצפן, ורק אחרי זה עובר מידע.

**SSL ו-TLS.** אם חניך אומר SSL, זה השם הישן שנשאר בדיבור. כל גרסאות SSL משנות ה-90 נשברו ובוטלו, ובשימוש היום TLS 1.2, שפורסם ב-2008, ו-TLS 1.3, שפורסם ב-2018. TLS נמצא גם ב-LDAPS מול ה-DC, ב-RDP וב-VPN, עם אותן תקלות. אין צורך להעמיק במתמטיקה או בכל הודעת משנה. התמונה המלאה בשיעור 8, שקופיות 27-28.

## שקופית 16 · בתקלת TLS בודקים זמן, שם, אמון ומשא ומתן

**על המסך:** ארבע משפחות: זמן או תוקף (שעון או תאריך שגוי), שם לא תואם (פנו בשם אחר), שרשרת לא מהימנה (Intermediate או Root), אין התאמה (גרסה או Cipher Suite).

**רקע.** כל משפחה נשברת בשלב אחר, ולכן הודעת השגיאה והשעה מצביעות על השלב שנשבר. שלוש הראשונות הן כשל באימות התעודה (שלב 4 בטבלה הקודמת). הרביעית היא כשל במשא ומתן, בשלבים 1-2, עוד לפני שהתעודה נשלחה. הפרידו ביניהם בהסבר.

| משפחה | שגיאה אופיינית ב-Chrome וב-Edge | מה בודקים |
|---|---|---|

| | | |
|---|---|---|
| **זמן או תוקף** | ERR_CERT_DATE_INVALID | תאריכי התעודה מול שעון התחנה. אם רק תחנה אחת נכשלת, החשוד הוא השעון שלה. |
| **שם לא תואם** | ERR_CERT_COMMON_NAME_INVALID | מה הוקלד מול רשימת ה-SAN. בדרך כלל נכנסו בכתובת IP או בשם קצר. |
| **שרשרת לא מהימנה** | ERR_CERT_AUTHORITY_INVALID | הלשונית Certification Path, וה-Root הפנימי ב-certlm.msc. |
| **אין התאמה** | ERR_SSL_VERSION_OR_CIPHER_MISMATCH | גרסת TLS ו-Cipher Suites בשני הצדדים, אירועי Schannel. |

לפני כל אלה מוודאים שהבעיה באמת ב-TLS: Test-NetConnection server -Port 443 ב-PowerShell. אם TcpTestSucceeded הוא True, הרשת והפורט תקינים והתקלה בשכבה שמעל.

**בשטח.** הודעת שגיאה מדויקת ותאריך המערכת חשובים יותר מצילום מסך חלקי. כשמעבירים תקלה הלאה, רושמים את נוסח השגיאה המלא, את השם שהוקלד, את התאריך והשעה בתחנה, ובכמה תחנות היא מופיעה. למי מעבירים נקבע בנוהל היחידה. פירוט לכל שגיאה בשיעור 8, שקופית 12.

> **לא לוחצים "המשך בכל זאת"**
>
> אזהרת התעודה היא בדיוק המצב שהבדיקה נועדה לעצור: ייתכן שהצד השני אינו השרת. מתעדים את השגיאה ומתקנים את החוליה שנכשלה.

# תרגול, מגבלות ושרשרת התלות

## שקופית 17 · אבחון תקלות כניסה ותעודה

**על המסך:** כפתורי דיווח 1 עד 4 ותיבה עם הדיווח של המשתמש והשאלה. מתחת אותם מתגים של "מצב התחנה" משקופית 2, ומשמאל אותה טבלה. מתחת לטבלה תיבה שמסמנת "✓ המצב בתחנה נותן בדיוק את הדיווח" כשהתוצאות בטבלה זהות לדיווח. הכפתור "⟲ הכול תקין" מחזיר את כל המתגים למצב תקין.

**ההדגמה.** התרגול הפוך לשקופית 2: שם שינו תשתית וראו מה המשתמש מקבל, וכאן מתחילים ממה שהמשתמש מדווח. בחרו דיווח, תנו לחניכים להציע מה לא תקין ולנמק, ושנו את המתג שהציעו. אם התיבה לא מסמנת ✓, שאלו מה בטבלה שונה מהדיווח. אחרי כל דיווח לחצו "הכול תקין". התשובות:

| דיווח | המצב שנותן אותו | למה, ואיך מאשרים בתחנה |
|---|---|---|
| **1** | שרת DNS "חיצוני" | ping לכתובת ה-IP של ה-DC עונה, כלומר הרשת תקינה. "אין IP" היה נותן באתר "אין חיבור לאתר" ולא "השם לא נמצא". מאשרים ב-ipconfig /all (אילו שרתי DNS התחנה קיבלה) וב-nltest /dsgetdc:unit.local. |
| **2** | קבוצה "לא חבר" | הכניסה עברה, אז האימות תקין, והעמית שפותח את התיקייה מאותה תחנה מראה שהתחנה והשרת תקינים. whoami /groups מציג את הקבוצות של המשתמש. איפוס סיסמה לא נוגע בהרשאות. אחרי הוספה לקבוצה המשתמש צריך לצאת ולהיכנס מחדש (שקופית 6). |
| **3** | שעון "שנה אחורה" | תחנה שעמדה זמן רב בלי חשמל, למשל עם סוללת שעון ריקה. "10+ דקות" היה מפיל רק את הכניסה; שגיאת התאריך בתעודה אומרת שהפער בימים ויותר. בודקים את התאריך בתחנה ואת w32tm /query /status (שקופית 8). |
| **4** | חשבון המחשב "סוד לא תואם" | בגיבוי שמורה סיסמת מחשב ישנה, וה-DC כבר מכיר סיסמה חדשה יותר שהתחנה קבעה אחרי הגיבוי. TLS לא משתמש בחשבון המחשב, ולכן האתר נפתח. Test-ComputerSecureChannel מחזיר False. התיקון לפי נוהל היחידה (שקופית 5). |

בדיווח 1 גם מצבים אחרים נותנים ✓, למשל DNS חיצוני יחד עם Root חסר, כי כשהשם לא נמצא הדפדפן לא מגיע לתעודה. זה בסדר: התרגול שואל איזו תקלה מסבירה את הדיווח, והתקלה ב-DNS קודמת לשאר.

> **טעות נפוצה**
>
> לקפוץ לתשובה לפי מילה אחת בדיווח ("כניסה נכשלה, אז סיסמה"). בכל דיווח יש פרט שמבדיל: ה-ping בדיווח 1, העמית בדיווח 2, שגיאת התאריך בדיווח 3 והאתר שעובד בדיווח 4.

## שקופית 18 · מגבלות ההדגמות

**על המסך:** טבלה: לכל הדגמה מה הופשט ומה יש בפועל, ומתחת מה בהדגמות כן כמו במערכת אמיתית, והפניה לשיעור 8 לשרשרת התעודות וללחיצת היד.

**רקע.** ההדגמות בנויות כך שכל מתג הוא תקלה אחת וברורה, וזה מה שמאפשר לראות את הקשר בין סיבה לתוצאה. בשטח המצב מבולגן יותר, וחשוב שהחניך יידע את זה לפני שהוא פוגש אותו:

- **מצב התחנה (שקופיות 2 ו-17).** DNS ראשי פנימי ומשני חיצוני נותן תקלה שמופיעה ונעלמת (שקופית 4). משתמש שנכנס מנתונים שמורים לא רואה הודעת כניסה בכלל ונתקע רק בתיקיות ובמדיניות. בתיקייה משותפת יש הרשאות

שיתוף והרשאות NTFS (שקופית 6). ונוסח ההודעות משתנה בין גרסאות Windows; לפעמים, כמו שמוסבר אצל שקופית 8, מופיעה רק שגיאת אימות כללית.

- **Kerberos (שקופית 7).** ההודעות מוצגות בלי השדות שלהן, ויש כרטיס שירות אחד. בכניסה אמיתית מתקבלים עוד כרטיסים, כרטיסים מתחדשים לפני שהם פגים, ובגישה לפי כתובת IP מערכת Windows עוברת בדרך כלל ל-NTLM.
- **שעון התחנה (שקופית 8).** 5 דקות היא ברירת המחדל, והערך בפועל נקבע במדיניות ה-Domain. ההשוואה נעשית ב-UTC. תחנה ב-Domain מסנכרנת את השעון שלה מה-DC, ולכן כשרואים פער גדול, הבעיה היא שהסנכרון עצמו לא עובד.

מה שכן כמו במערכת אמיתית: סדר ההודעות ב-Kerberos, סף ברירת המחדל, והתלות של הכניסה ב-DNS, בזמן ובחשבון המחשב. לא לדלג על השקופית. אחרי ההדגמות חניכים מצפים שלכל תקלה תהיה הודעה אחת ברורה.

## שקופית 19 · בלי רשת, DNS, זמן וזהות תקינים, Domain ו-TLS לא יעבדו

**על המסך:** חמש עמודות: רשת (Link, IP ונתיב), DNS (איתור DC ושירות), זמן (תוקף כרטיס ותעודה), זהות (משתמש ומחשב), TLS (אמון ומשא ומתן).

סיימו בתלות בין התשתיות, בלי לחזור על כל המושגים. כל עמודה נשענת על אלה שלפניה: בלי רשת אין DNS, בלי DNS לא מוצאים DC, בלי שעון נכון כרטיסים ותעודות נדחים, ובלי זהות תקינה אין אימות. לכן תקלה באימות מתחילה הרבה פעמים בתשתית אחרת, ובודקים מלמטה למעלה. אפשר לבקש מחניך לענות עכשיו על שאלת הפתיחה בעזרת העמודות, או לחזור לשקופית 2 ולשאול, בכל מצב שם, איזו עמודה נשברה.

**שאלת סיום**

השרת נגיש ב-IP ובפורט, אבל TLS נכשל. מה בודקים לפני שמאשימים את היישום? תשובה טובה עוברת על המשפחות משקופית 16: שעון התחנה ותוקף התעודה, השם שבו פנו מול השמות שבתעודה, השרשרת עד Root מהימן, והתאמה של גרסה ו-Cipher Suite.

# מפת המצגת, ערכי בדיקה, פקודות ומילון

## מפת המצגת

| מס׳ | כותרת השקופית | מס׳ | כותרת השקופית |
|---|---|---|---|
| 1 | בסביבת Windows, זהות ו-TLS נשענים על DNS, זמן ושרשרת אמון | 11 | הצפנה אסימטרית ב-Handshake, סימטרית לתעבורה |
| 2 | על מה נשענות כניסה וגישה לשירותים | 12 | תעודה קושרת שם למפתח ציבורי, והמנפיק חותם עליה |
| 3 | ב-Domain יש חשבון גם למשתמש וגם למחשב | 13 | אמון נבנה מהתעודה דרך מנפיקים עד Root מוכר |
| 4 | תחנה מאתרת Domain Controller באמצעות DNS | 14 | הלקוח מציע אפשרויות, והשרת בוחר שילוב ששניהם תומכים בו |
| 5 | Domain Join יוצר למחשב חשבון וערוץ מאובטח | 15 | ה-Handshake מאמת את השרת וגוזר מפתחות לפני שעובר מידע יישומי |
| 6 | אימות בודק מי המשתמש, והרשאה קובעת מה מותר לו | 16 | בתקלת TLS בודקים זמן, שם, אמון ומשא ומתן |
| 7 | Kerberos משתמש בכרטיסים כדי להוכיח זהות לשירותים | 17 | אבחון תקלות כניסה ותעודה |
| 8 | שעון שגוי נראה כמו תקלה באימות | 18 | מגבלות ההדגמות |
| 9 | מדיניות Domain יכולה לשנות שירותים, חומת אש ואמון בתחנה | 19 | בלי רשת, DNS, זמן וזהות תקינים, Domain ו-TLS לא יעבדו |
| 10 | חיבור מאובטח צריך סודיות, שלמות ואימות זהות | | |

## ערכי בדיקה להדגמות

אם רוצים לוודא לפני השיעור שההדגמות עובדות, אלה התוצאות שצריכות להופיע:

| הדגמה | מצב | תוצאה |
|---|---|---|
| **מצב התחנה (שקופית 2)** | ברירת המחדל: שעון 10+ דקות | כניסה: הפרש שעה ותאריך · תיקייה: לא נבדקה · אתר: מצליחה |
| | שעון ״שנה אחורה״ | כניסה נכשלת · אתר: ERR_CERT_DATE_INVALID |
| | שעון מדויק, DNS חיצוני | כניסה: אין שרת כניסה זמין · אתר: השם לא נמצא |
| | שעון מדויק, קבוצה ״לא חבר״ | כניסה מצליחה · תיקייה: אין הרשאת גישה · אתר מצליחה |

| | | |
|---|---|---|
| **Kerberos (שקופית 7)** | מונה 7 / 3 ו-7 / 5 | klist: krbtgt/UNIT.LOCAL 08:00:00-18:00:00, ואחריו cifs/fs01.unit.local 08:05:00-18:00:00 |
| **שעון (שקופית 8)** | ברירת המחדל +7 · +5 · −6 | 09:07:00 נדחית · מתקבלת · נדחית; התעודה בתוקף בשלושתם |
| | "שנה אחורה" / "שנה קדימה" | 10/11/2025 התעודה עוד לא בתוקף / 10/11/2027 פג תוקף התעודה |
| **תרגול (שקופית 17)** | דיווחים 1 עד 4: DNS חיצוני · לא חבר · שנה אחורה · סוד לא תואם | ✓ המצב בתחנה נותן בדיוק את הדיווח |

## פקודות שמוזכרות במדריך

אם מריצים פקודות על תחנה בכיתה, אלה הפקודות שהמדריך מזכיר. כולן קוראות מידע בלבד, חוץ מ-gpupdate ו-klist purge, שמרעננים מדיניות וכרטיסים.

| פקודה | מה היא מראה | שקופית |
|---|---|---|
| **whoami · echo %LOGONSERVER%** | בשם מי מחוברים, ואיזה DC אימת | 3 |
| **ipconfig /all · nltest /dsgetdc:<domain>** | שרתי ה-DNS של התחנה, ואיתור DC | 4, 17 |
| **Test-ComputerSecureChannel** | מצב הערוץ המאובטח | 5, 17 |
| **whoami /groups** | הקבוצות באסימון הנוכחי | 6 |
| **klist · klist purge** | כרטיסי Kerberos ותוקפם, ומחיקתם | 7 |
| **w32tm /query /status · w32tm /query /source** | הסנכרון האחרון ומקור הזמן | 8 |
| **gpresult /r · gpresult /h · gpupdate /force** | אילו GPO הוחלו, דוח מלא, ריענון | 9 |
| **certlm.msc · certutil -verify -urlfetch** | מאגר התעודות של המחשב, ובדיקת שרשרת | 12-13 |
| **Test-NetConnection -Port 443** | האם הפורט פתוח, לפני שחושדים ב-TLS | 16 |

## מילון קצר

| מונח | הסבר | מונח | הסבר |
|---|---|---|---|
| **Domain** | גבול ניהולי של זהות, אמון ומדיניות. | **CA** | רשות שחותמת על תעודות. |
| **SRV** | רשומת DNS שמצביעה על שרת של שירות ועל הפורט שלו. | **SAN** | רשימת השמות שהתעודה תקפה להם. |
| **Secure Channel** | הערוץ המאובטח בין התחנה ל-DC, על בסיס סיסמת חשבון המחשב. | **Cipher Suite** | ב-TLS 1.3: הצפנת התעבורה וה-Hash שנבחרו. |
| **Kerberos / TGT** | אימות בכרטיסים מוגבלי זמן / הכרטיס הראשי שמתקבל בכניסה. | **ECDHE** | דיפי-הלמן זמני: הסכמה על סוד בלי לשלוח אותו. |

| | | | |
|---|---|---|---|
| **NTLM** | שיטת אימות ישנה, שמשמשת כשאין Kerberos. | **מפתח Session** | מפתח סימטרי זמני לחיבור אחד. |
| **GPO** | אובייקט מדיניות שמוחל על מחשבים ומשתמשים. | **Handshake** | הסכמה ואימות לפני מידע יישומי. |
| **KDC** | השירות ב-DC שמנפיק כרטיסי Kerberos. | **כרטיס שירות** | כרטיס Kerberos לשירות אחד, מוצפן במפתח של חשבון השירות. |